

API Security Risk Analysis Report

Submitted by

Diksha Gholap

(Cyber security intern)

INDEX

Sr No.	Title	Page
1	Introduction	3
2	Objectives of the Analysis	4
3	Tools Used	5
4	API Details	6
5	Methodology	7
6	Identified Security Risks	8
7	Screenshot Evidence	11
8	Risk Impact Summary	14
9	Recommendations	15
10	Conclusion	16

INTRODUCTION

Application Programming Interfaces (APIs) play a critical role in modern software development by enabling communication between different applications, services, and platforms. APIs are widely used in web applications, mobile apps, cloud services, and enterprise systems to exchange data and perform operations efficiently. Due to their widespread use, APIs have become a common target for cyber attackers.

API security is an essential aspect of overall application security. Poorly designed or improperly secured APIs can expose sensitive data, allow unauthorized access, and lead to serious security incidents such as data breaches, account takeovers, and denial-of-service attacks. Many real-world cyber attacks occur not because of complex exploits, but due to basic security issues like missing authentication, weak authorization, excessive data exposure, and lack of rate limiting.

This report presents an API Security Risk Analysis conducted on a publicly available demo API. The purpose of this analysis is to identify common API security vulnerabilities, understand their potential impact, and recommend suitable remediation measures. The analysis focuses on evaluating authentication mechanisms, authorization controls, response data exposure, and API usage limits.

The testing was performed using Postman by sending GET requests to selected API endpoints and analyzing the responses and HTTP headers. The API was accessed without any authentication to determine whether security controls were enforced. All identified risks are explained in simple and business-friendly language to help both technical and non-technical stakeholders understand the security implications.

Through this analysis, the report aims to demonstrate practical knowledge of API security fundamentals and highlight the importance of following best practices and industry standards such as the OWASP API Security Top 10. The findings and recommendations provided in this report can help organizations improve their API security posture and reduce the risk of cyber threats.

OBJECTIVES OF THE ANALYSIS

The objectives of this analysis are:

- APIs To analyze API endpoints using a security testing tool
- To identify common API security vulnerabilities
- To understand risks related to authentication and authorization
- To explain security issues in simple, business-friendly language
- To suggest remediation techniques for securing APIs

TOOLS USED

The following tools were used during the analysis:

- **Postman** – To send API requests and analyze responses
- **Web Browser** – For API validation
- **MS Word / PDF** – For documentation

API DETAILS

API Name: JSONPlaceholder

Base URL:

<https://jsonplaceholder.typicode.com>

Purpose:

JSONPlaceholder is a publicly available REST API designed for testing, learning, and prototyping purposes. It provides fake but realistic data that helps developers and security analysts test API functionality and analyze potential security issues without impacting real-world systems.

Endpoints Tested:

- **GET /users** – Retrieves a list of user details such as name, username, email, and address.
- **GET /posts** – Returns posts created by users, including title and content information.
- **GET /comments** – Provides comments associated with user posts.

METHODOLOGY

The API security analysis was performed using the following steps:

1. Selected a public demo API for testing
2. Sent GET requests using Postman
3. Observed API response data in JSON format
4. Analyzed HTTP response headers
5. Tested API access without authentication
6. Identified potential security risks
7. Documented findings and recommendations

IDENTIFIED SECURITY RISKS

Risk 1: Missing Authentication

Description:

The API allows access to its endpoints without requiring any authentication mechanism such as API keys or tokens.

Impact:

Unauthorized users can access sensitive data, which may lead to data leakage and misuse.

Risk Level: High

OWASP Reference: API2 – Broken Authentication

Remediation:

- Implement API authentication using API keys or JWT
- Restrict access to sensitive endpoints
- Enforce secure authentication policies

Risk 2: Broken Authorization

Description:

The API does not enforce authorization checks, allowing users to access data belonging to other users.

Impact:

This can result in privacy violations and unauthorized data access.

Risk Level: High

OWASP Reference: API1 – Broken Object Level Authorization

Remediation:

- Implement role-based access control (RBAC)
- Validate user permissions for each request

Risk 3: Excessive Data Exposure**Description:**

The API responses expose more data than necessary, including full user details.

Impact:

Excessive exposure increases the risk of information disclosure and system reconnaissance.

Risk Level: Medium

OWASP Reference: API3 – Excessive Data Exposure

Remediation:

- Return only required fields in API responses
- Apply data filtering mechanisms

Risk 4: Missing Rate Limiting**Description:**

The API does not restrict the number of requests that can be made within a given time.

Impact:

Attackers can overload the API, leading to Denial-of-Service (DoS) attacks.

Risk Level: Medium

OWASP Reference: API4 – Lack of Resources & Rate Limiting

Remediation:

- Implement rate limiting and throttling
- Monitor abnormal request patterns

SCREENSHOT EVIDENCE

Figure 1: API GET Request

Description: This screenshot shows a GET request sent to the /users endpoint using Postman. The request was successful and returned a 200 OK status without requiring authentication.

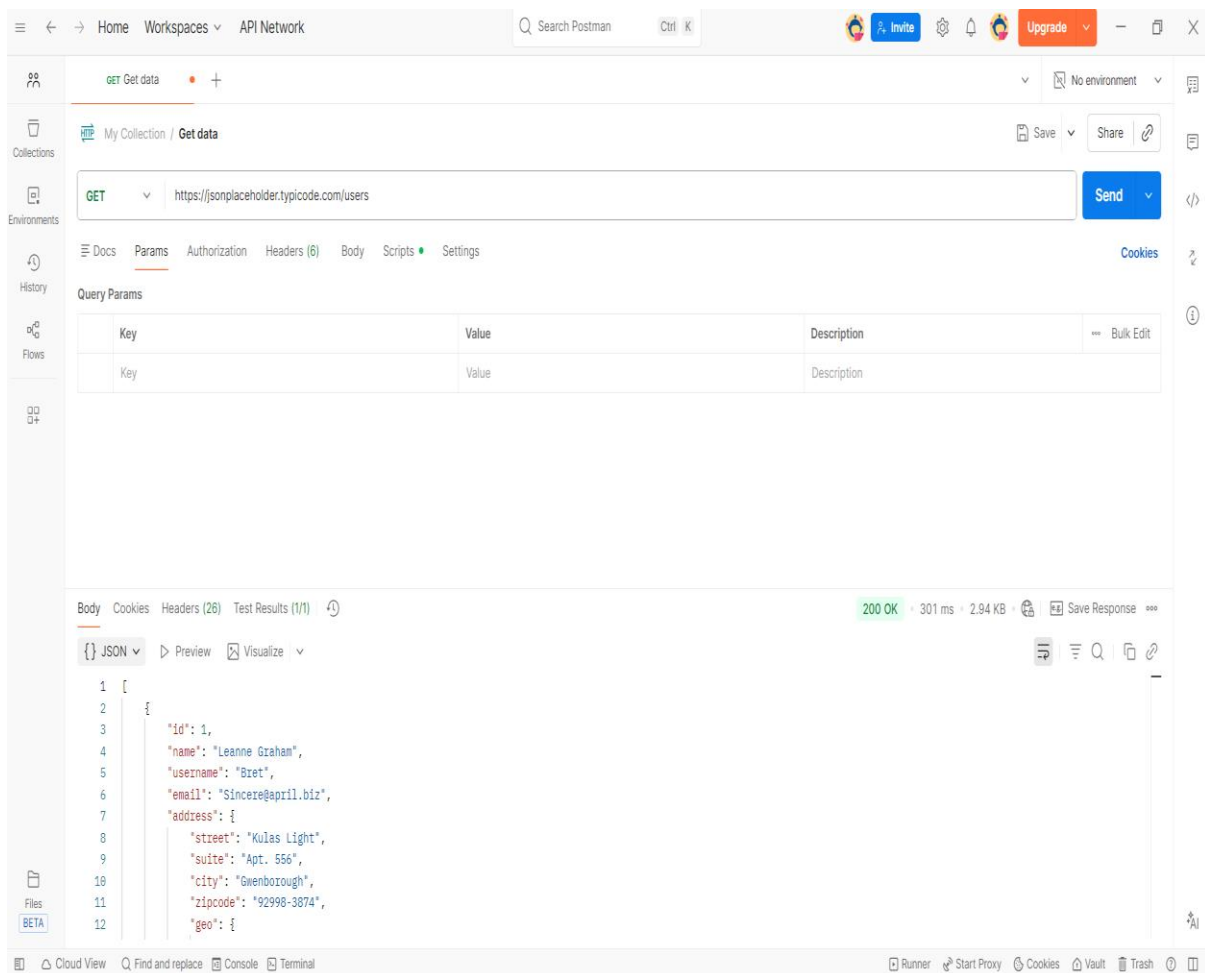


Figure 2: API Response Data

Description: This screenshot displays the API response containing user data in JSON format, demonstrating that the data is accessible without authentication.

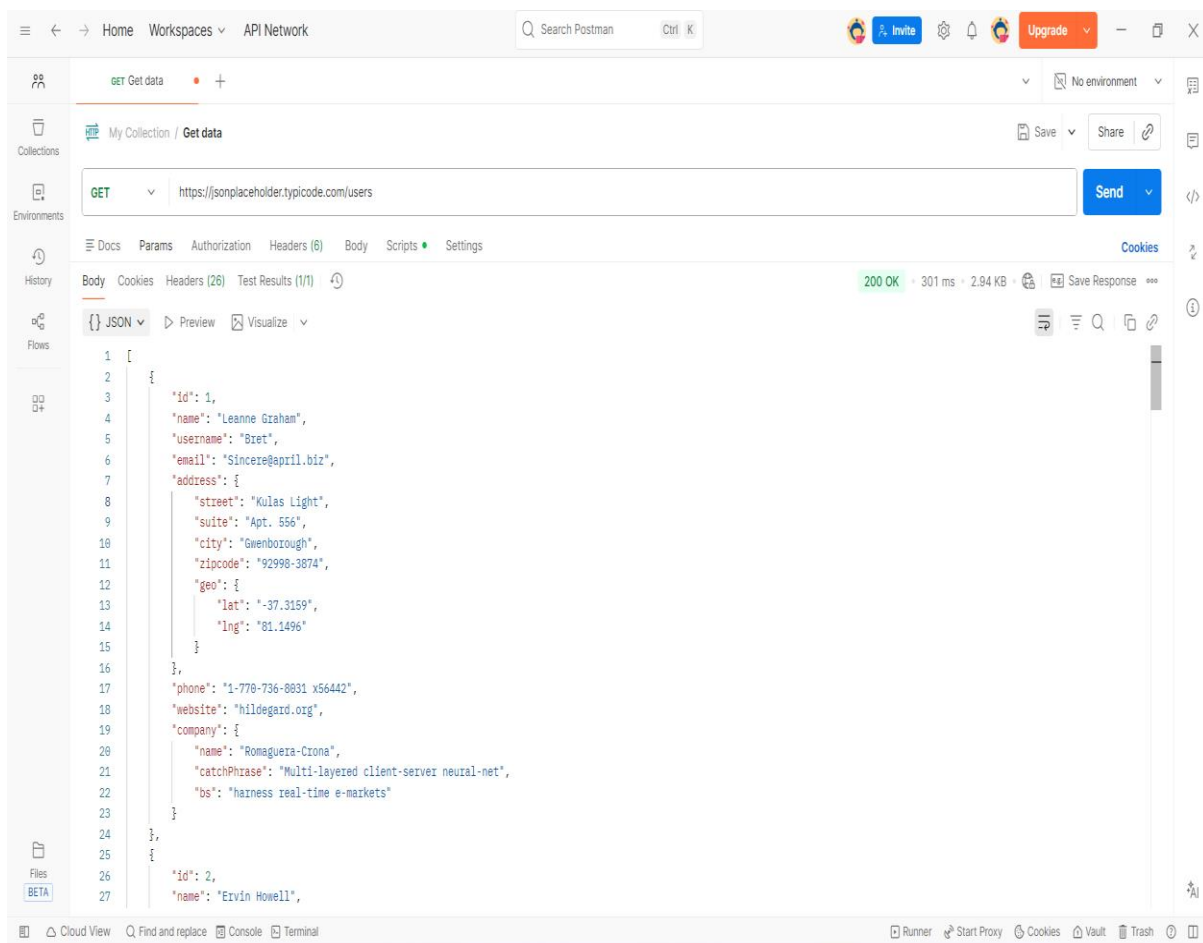
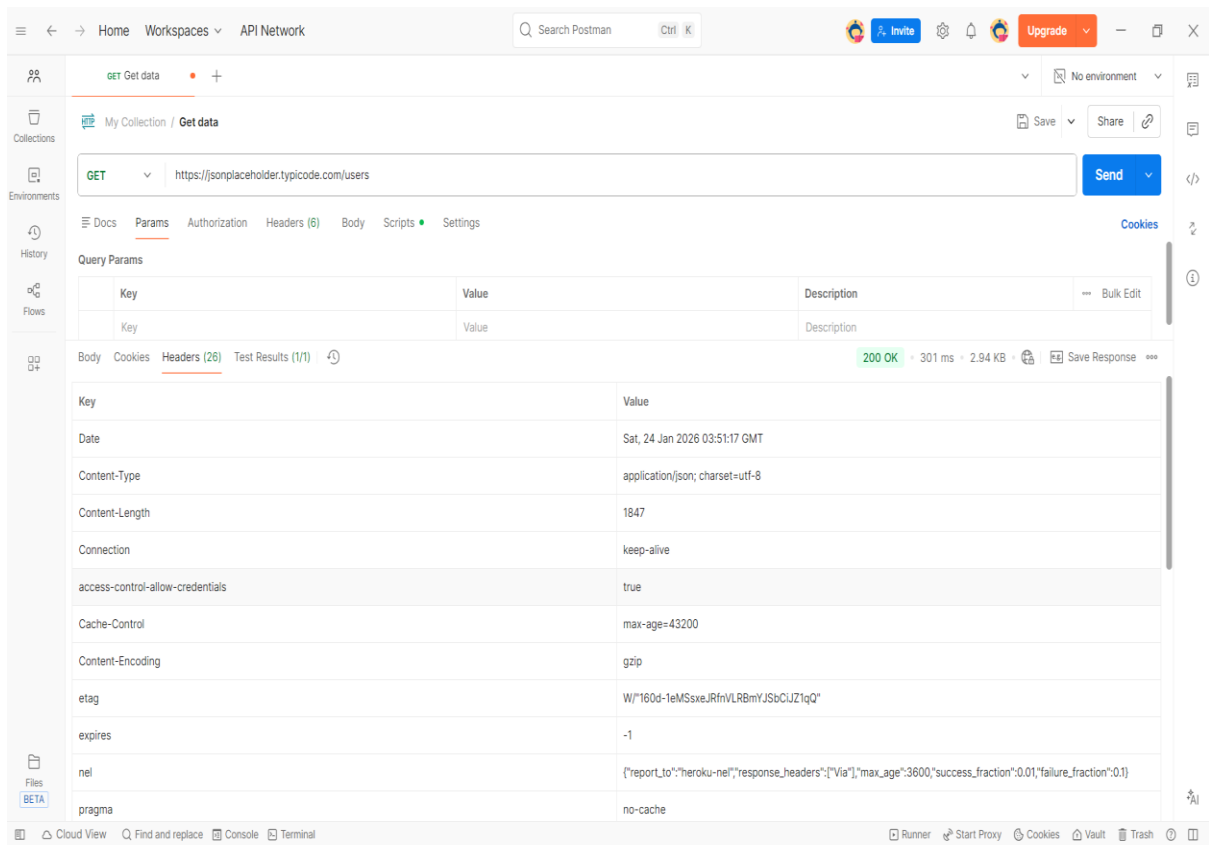


Figure 3: API Response Headers

Description: This screenshot shows HTTP response headers such as Content-Type and Cache-Control, indicating successful API communication without security enforcement.



RISK IMPACT SUMMARY

Risk	Impact	Impact
Missing Authentication	Unauthorized access to data	High
Broken Authorization	Data leakage	High
Excessive Data Exposure	Information disclosure	Medium
Missing Rate Limiting	Service disruption	Medium

RECOMMENDATIONS

- Enforce strong authentication mechanisms
- Implement authorization checks for all endpoints
- Limit data exposure in API responses
- Apply rate limiting to prevent abuse
- Follow OWASP API Security Top 10 guidelines

CONCLUSION

This API Security Risk Analysis demonstrates how common security vulnerabilities can exist in publicly accessible APIs. The analysis highlights the importance of implementing authentication, authorization, and rate limiting to protect APIs from unauthorized access and misuse. Applying recommended security measures can significantly improve the overall security posture of APIs.